

RCS HRMS Pro

Complete Payroll Application Audit Report

Audit Date: 07 July 2026
Database: rcsfaxhz_bolt (MariaDB 10.6.25)
98 Tables | 180+ PHP Files | 15 API Endpoints

Severity	Count	Summary
CRITICAL	18	Data loss, runtime crashes, security breaches, compliance violations
HIGH	24	Incorrect calculations, missing data, broken reports, performance issues
MEDIUM	22	Wrong defaults, hardcoded values, incomplete validations
LOW	12	Naming inconsistencies, cosmetic issues, minor optimizations

Table of Contents

1. Executive Summary	4
1.1 Audit Scope	4
2. Critical Issues (18)	4
2.1 Database Schema Critical Issues	4
C1. 20 Tables Missing from Database	4
C2. payroll.employee_id Stores employee_code, Not ID	5
C3. Zero Foreign Keys on 90+ Tables	5
C4. attendance Table Schema Mismatch	5
2.2 Security Critical Issues	5
C5. image-tool.php Has Zero Authentication	5
C6. Employee Portal Login Uses No Password or OTP	6
2.3 Payroll Processing Critical Issues	6
C7. payroll-update.php Writes to Non-Existent basic/da Columns	6
C8. payroll-update.php Hardcodes All Deductions	6
C9. Payroll View Shows basic and da Separately (Always Zero)	6
C10. N+1 Query Storm in Payroll Processing	7
C11. attendance_summary Upsert Missing unit_id	7
2.4 Reports Critical Issues	7
C12. Reports Use e.status = 1 Instead of e.status = approved	7
C13. PF Reports Reference Non-Existent pf_number Column	7
C14. PF Sub-Reports Use status = 1 Instead of is_active = 1	7
C15. Employee Delete Without Active Payroll Check	7
C16. Salary Structure Update Overwrites Without Versioning	8
C17. Bonus Module Uses Wrong Employee Status Values	8
C18. ESI Return Uses Pro-Rated Gross for Eligibility	8
3. High Priority Issues (24)	9
4. Medium Priority Issues (22)	11
5. Low Priority Issues (12)	11
6. Recommended Fixes and Execution Plan	13
6.1 Immediate Actions (Before Next Deployment)	13
6.2 Short-Term Actions (Next Sprint)	13

6.3 Medium-Term Actions (Next Quarter) 13

7. Database Recommended Changes 14

7.1 Tables to Create 14

7.2 Tables to Drop 14

7.3 Critical Indexes to Add 14

8. Positive Findings 15

9. Cross-Module Data Flow Validation 16

1. Executive Summary

This report presents the findings of a comprehensive end-to-end audit of the RCS HRMS Pro Payroll Management System. The audit covered 98 database tables, 180+ PHP files across 35+ modules, 15 API endpoints, and all security controls. The system is a PHP/MySQL payroll application deployed at join.rcsfacility.com, serving multiple clients with employee management, attendance tracking, payroll processing, statutory compliance, and reporting capabilities.

The audit identified **76 total findings** across 17 audit categories: 18 Critical, 24 High, 22 Medium, and 12 Low severity. The most pressing issues include: (a) 20 database tables referenced in PHP code that do not exist in the SQL schema, causing runtime crashes; (b) zero foreign key constraints on 90+ tables, leaving data integrity unprotected; (c) two critical security vulnerabilities allowing unauthenticated access to employee documents and portal data; (d) incorrect payroll calculations in multiple API endpoints; (e) N+1 query performance issues in the payroll processing engine that will cause timeouts with 500+ employees; and (f) multiple report files using wrong column names and status values, causing them to return zero results or SQL errors.

The positive findings include: robust parameterized query usage throughout (PDO with EMULATE_PREPARES=false), proper bcrypt password hashing, effective brute-force protection on admin login, secure session management with HttpOnly/SameSite/Secure cookies, comprehensive audit logging, and a well-structured RBAC menu permission system. These controls demonstrate a solid security foundation that needs to be extended to the API layer and employee portal.

1.1 Audit Scope

Metric	Count	Details
Database Tables	98	MariaDB 10.6.25, rcxfaxhz_bolt
PHP Files	180+	35+ module directories
API Endpoints	15	modules/api/ directory
Menu Items	55+	All verified to map to existing files
Orphan Pages	60+	Accessible via URL but not in menu
Missing Tables	20	Referenced in PHP but not in SQL dump
Duplicate Tables	8 pairs	employees1/2, leave_balances variants, etc.
Foreign Keys	5 only	Out of 90+ parent-child relationships

2. Critical Issues (18)

Critical issues represent immediate risks of data loss, security breaches, compliance violations, or complete feature failure. These must be addressed before the next deployment cycle. Each finding below includes the exact file, root cause analysis, impact assessment, and a specific recommended fix.

2.1 Database Schema Critical Issues

C1. 20 Tables Missing from Database

20 Tables Referenced in PHP Code Do Not Exist in Database

Multiple PHP modules

Location: Various

Root Cause: The SQL dump (rcsfaxhz_bolt.sql) contains 98 tables, but PHP code actively queries 20 additional tables that do not exist. These include: daily_attendance, employee_arrears, employee_bonus, employee_deployments, employee_family, esi_returns, fine_register, job_applicants, manpower_requisitions, pf_ecr_files, pf_form5_submissions, pf_remissions, pt_challans, saved_reports, timesheets, timesheet_entries, accident_register, client_feedback, client_timesheets, and employee_advance (singular). The SQL dump may be incomplete, or these tables were never created.

Impact: Every module that references a missing table will crash with a fatal SQL error. This affects: attendance reports (Gumastadhara), muster roll reports, PF compliance filings, ESI return generation, PT challan management, recruitment, timesheets, and expense tracking.

Recommended Fix: Regenerate the SQL dump from the live database to verify. If tables truly do not exist, create them based on the column references found in the PHP code. Prioritize: daily_attendance (used by class.attendance.php for daily CRUD), employee_deployments, and pt_challans (used by compliance modules).

C2. payroll.employee_id Stores employee_code, Not ID

payroll Table Column Misleadingly Named employee_id But Stores employee_code

includes/class.payroll.php, payroll table schema

Location: payroll.employee_id (int), all JOINS using p.employee_id = e.employee_code

Root Cause: The payroll table column named "employee_id" actually stores the employee_code value (an integer code like 101, 102), NOT the employees.id primary key. This is confirmed by 18+ JOIN statements in class.payroll.php that join p.employee_id = e.employee_code. The payroll_records table has the same issue. Additionally, payroll_exceptions.employee_id is varchar(36) while all other tables use int(11), creating type inconsistency.

Impact: Every developer interacting with the payroll table will assume employee_id refers to employees.id, leading to incorrect JOINS, wrong data lookups, and data corruption during migrations. The type mismatch (int vs varchar) prevents proper foreign key creation and causes implicit type conversion in queries.

Recommended Fix: Rename the column: ALTER TABLE payroll CHANGE employee_id employee_code int(10) UNSIGNED NOT NULL; Do the same for payroll_records. Update all PHP JOINS from p.employee_id = e.employee_code to p.employee_code = e.employee_code. This is a high-effort change requiring careful testing across all payroll and report modules.

C3. Zero Foreign Keys on 90+ Tables

Only 5 Foreign Key Constraints Exist Across Entire Database

All tables with client_id, unit_id, employee_id, period_id, loan_id

Location: Schema-wide: only employees, ess_checklist_items, invoice_items, invoice_payments, salary_formula_components, unit_salary_formulas have FKs

Root Cause: Out of 98 tables, only 5 tables have foreign key constraints defined. Every parent-child relationship (payroll to periods, attendance to employees, loans to employees, invoices to clients, etc.) has no database-level integrity enforcement. This means orphan records can be created freely: deleting a client leaves payroll records pointing to non-existent clients, and inserting payroll for a non-existent period succeeds silently.

Impact: Data integrity is entirely dependent on application-level code. Any bug, race condition, or direct database access can create orphan records that corrupt reports, cause cascade failures, and make data cleanup extremely difficult. Multi-year data consistency is at risk.

Recommended Fix: Add FK constraints for all critical relationships. Start with the highest-risk tables: payroll (period_id, unit_id), attendance_summary (employee_id, unit_id), employee_advances (employee_id), employee_loans (employee_id), and payroll_unit_status (period_id, unit_id). Use ON DELETE RESTRICT for payroll and attendance to prevent accidental deletion.

C4. attendance Table Schema Mismatch

attendance Table Has Monthly Schema But PHP Expects Daily Records

modules/attendance/upload.php, includes/class.attendance.php:154

Location: attendance table columns: employee_id, month, year, total_present, total_extra, overtime_hours, total_wo, total_paid_days

Root Cause: The attendance table in the database is structured for monthly aggregated data (month, year, total_present columns). However, class.attendance.php:154 attempts to INSERT daily records with columns: attendance_date, status, in_time, out_time, working_hours. These columns do not exist in the current table. Reports reference a daily_attendance table that also does not exist.

Impact: The attendance import feature (Excel upload), manual attendance entry, and daily attendance viewing will all fail with SQL errors when attempting to insert or query daily attendance data. This is a core feature that is completely broken at the database level.

Recommended Fix: Create a daily_attendance table with: id (AUTO_INCREMENT), employee_id (INT), attendance_date (DATE), unit_id (INT), status (VARCHAR), in_time (TIME), out_time (TIME), working_hours (DECIMAL), overtime_hours (DECIMAL), remarks (TEXT), source (ENUM), uploaded_by (INT), created_at (TIMESTAMP), updated_at (TIMESTAMP). Add UNIQUE KEY on (employee_id, attendance_date).

2.2 Security Critical Issues

C5. image-tool.php Has Zero Authentication

Image Tool API Allows Unauthenticated Browsing, Reading, and Deletion of All Employee Documents

modules/api/image-tool.php

Location: Entire file (lines 1-256)

Root Cause: The image-tool.php API endpoint has absolutely no authentication or authorization check. Any anonymous user on the internet can access it via the URL parameter ie_action and perform: browse all uploaded folders, read any uploaded file, delete any file, upload new files, and rename files. The index.php router does check auth for some API modules but image-tool.php has no session check within the file itself.

Impact: An attacker can enumerate and download every employee Aadhaar card, PAN card, bank documents, and profile photos. They can also delete any uploaded document, causing irreversible data destruction. This is a severe PII breach.

Recommended Fix: Add authentication at the top: if (!isset(\$_SESSION["user_id"])) { http_response_code(401); exit; }. Restrict to admin and HR roles only. Validate file paths are within the upload directory. Add audit logging.

C6. Employee Portal Login Uses No Password or OTP

Portal Authentication Uses Only Employee Code or Mobile Number With No Second Factor

modules/portal/login.php

Location: Lines 25-100

Root Cause: The employee portal authenticates users using only their mobile_number OR employee_code, with no password, OTP, or MFA. There is no brute force protection. The login form also lacks CSRF protection, and error/success messages are output without escaping (XSS). Session regeneration is not called after login (session fixation risk).

Impact: Anyone who knows or guesses an employee code (often sequential like EMP001) gets full access to that employee portal: payslips, attendance, profile with PII (Aadhaar, PAN, bank details), and leave management.

Recommended Fix: Implement OTP-based authentication. Add rate limiting (max 5 attempts per 15 minutes). Add CSRF token. Escape all output with htmlspecialchars(). Call session_regenerate_id(true) after login.

2.3 Payroll Processing Critical Issues

C7. payroll-update.php Writes to Non-Existent basic_da Columns

AJAX Payroll Update Endpoint Writes to Ghost Columns basic and da Instead of basic_da

modules/api/payroll-update.php

Location: Lines 95-98

Root Cause: The endpoint splits basic_da into separate basic and da columns with hardcoded 60/40 ratio. The payroll table uses a single basic_da column. The comment incorrectly claims the table has separate columns.

Impact: Every AJAX payroll update will throw a SQL error or write to ghost columns while leaving basic_da as zero. All subsequent payslips and reports show Basic+DA as zero.

Recommended Fix: Replace lines 96-98 with: "basic_da" => \$basicDA. Remove the arbitrary 60/40 split entirely.

C8. payroll-update.php Hardcodes All Deductions

AJAX Payroll Update Hardcodes PF/ESI/PT Rates, Missing LWF and Loan EMI

modules/api/payroll-update.php

Location: Lines 77-91

Root Cause: The endpoint hardcodes PF at 12% capped at 15000, ESI at 0.75% capped at 21000, PT as flat 200. This bypasses database-driven rates, state-wise PT slab lookup, LWF deduction, loan_emi, and office_deduction.

Impact: Net pay is incorrect whenever rates differ from defaults, LWF is applicable, or employee has active loan. Creates discrepancy between main payroll batch and individual AJAX updates.

Recommended Fix: Extract deduction calculation from processPayroll() into reusable method. Both endpoints should call same method.

C9. Payroll View Shows basic and da Separately (Always Zero)

Payroll Detail and List Views Display Non-Existent basic and da Columns

modules/payroll/view.php

Location: Lines 75-76 (detail modal), line 395 (list table)

Root Cause: The view displays Basic and DA using \$detail["basic"] and \$detail["da"]. The payroll table has no separate basic or da columns (only basic_da). These always resolve to 0.00.

Impact: Finance team sees incomplete salary breakdowns on every payroll view. Directly erodes trust in the system.

Recommended Fix: Replace two separate rows with single row: "Basic + DA" showing \$detail["basic_da"]. Change \$p["basic"] to \$p["basic_da"].

C10. N+1 Query Storm in Payroll Processing

processPayroll() Executes 5-7 SQL Queries Per Employee

includes/class.payroll.php

Location: Lines 334-746 (the foreach loop)

Root Cause: Inside the employee loop: attendance fetch, LWF rate fetch, advance fetch, office deduction fetch, loan EMI fetch, minimum wage fetch. For 500 employees = 3,500+ SQL queries in a single payroll run.

Impact: Payroll processing for 500+ employees takes 30-120 seconds, risks PHP timeout, and degrades performance for all users.

Recommended Fix: Batch all queries before the loop using PHP associative array lookups. Reduces 3,500 queries to approximately 10.

C11. attendance_summary Upsert Missing unit_id

payroll-save-row.php Upserts attendance_summary Without unit_id

modules/api/payroll-save-row.php

Location: Lines 143-165

Root Cause: The upsert data array and SELECT query omit unit_id. The unique key is (employee_id, unit_id, month, year). For multi-unit employees, this fails or updates the wrong record.

Impact: Attendance data corruption for multi-unit employees. Wrong attendance days lead to incorrect salary.

Recommended Fix: Add unit_id to the data array. Update SELECT WHERE to include unit_id.

2.4 Reports Critical Issues

C12. Reports Use e.status = 1 Instead of e.status = approved

Multiple Report Files Filter Employees with Integer Status Instead of String

bonus-register.php:37, department-salary-register.php:21, leave-register.php:35, gratuity-form-f.php:33

Location: WHERE e.status = 1

Root Cause: The employees table uses VARCHAR status values like "approved" (per constants.php). Four reports use integer comparison e.status = 1 which matches zero rows.

Impact: Bonus Register, Department Salary Register, Leave Register, and Gratuity Form F show zero employees. These are critical compliance reports for statutory filings.

Recommended Fix: Replace e.status = 1 with e.status = "approved" in all four files.

C13. PF Reports Reference Non-Existent pf_number Column

PF Reports SELECT e.pf_number But employees Table Has uan_number

modules/report/pf-reports.php:28,49; modules/report/custom.php:30

Location: SELECT e.pf_number ... FROM employees e

Root Cause: The employees table has uan_number, not pf_number. The getBaseColumns() method confirms pf_number is not valid.

Impact: All PF report queries fail with "Unknown column pf_number". PF Account Register and Form 3A/6A are completely broken.

Recommended Fix: Replace all e.pf_number with e.uan_number in pf-reports.php and custom.php.

C14. PF Sub-Reports Use status = 1 Instead of is_active = 1

PF Form 5, Form 9, Dues Remitted, Cover Exempt Filter Clients Wrong

pf/form-9.php:100, dues-remitted.php:113, form-5.php:164, cover-exempt.php:125

Location: WHERE status = 1 on clients table

Root Cause: Clients table uses "is_active" (tinyint), not "status". These reports always get empty client/unit dropdowns.

Impact: All PF form generation reports show empty dropdowns, making PF filing impossible.

Recommended Fix: Replace "WHERE status = 1" with "WHERE is_active = 1" in all four affected files.

C15. Employee Delete Without Active Payroll Check

Employee Deletion Does Not Verify Active Payroll or Loan Records

modules/employee/delete.php:27-29, includes/class.employee.php:494-501

Location: *delete.php* uses *\$db->prepare()* to set *status=removed* without *pre-checks*

Root Cause: No check for active payroll records, attendance, outstanding loan balances, or settlements in progress.

Impact: Employee with processed payroll can be removed, orphaning historical data and causing re-processing issues.

Recommended Fix: Query payroll, attendance, loans, settlements before deleting. Block if active records exist or require admin confirmation.

C16. Salary Structure Update Overwrites Without Versioning

Employee Salary Edit Directly Updates Active Structure Instead of Creating New Version

includes/class.employee.php:462-491

Location: *Lines 469-483* directly *UPDATE* the current *employee_salary_structures* row

Root Cause: The code directly updates the current record without checking if payroll is already processed, and does not create a new versioned record with proper *effective_to* dates.

Impact: If payroll is processed for month X with salary A, editing to B makes the register inconsistent. No audit trail exists.

Recommended Fix: Check if payroll exists for current month. Set *effective_to* = *CURDATE()* - 1 on old record. Insert new record with *effective_from* = *CURDATE()*. This preserves historical accuracy and creates a proper audit trail.

C17. Bonus Module Uses Wrong Employee Status Values

Bonus Calculation Filters for "active" But System Uses "approved"

modules/payroll/bonus.php:37

Location: *WHERE e.status IN ("active", "resigned", "terminated")*

Root Cause: The system uses "approved" as primary active status. The bonus module queries for "active" which misses most employees.

Impact: Zero eligible employees found for bonus calculation. Bonus payments cannot be processed.

Recommended Fix: Change to: *WHERE e.status IN ("approved", "active", "resigned", "terminated")*.

C18. ESI Return Uses Pro-Rated Gross for Eligibility

ESI Return Data Query Uses Pro-Rated gross_earnings Instead of Full-Month Gross

includes/class.payroll.php:1406

Location: *AND p.gross_earnings <= 21000*

Root Cause: ESI eligibility should check full-month gross from salary structures, not pro-rated payroll *gross_earnings*. Employee with gross 25000 working half month has *gross_earnings* ~12500, incorrectly passing the 21000 threshold.

Impact: ESI returns include ineligible employees, causing compliance violations and potential ESIC penalties.

Recommended Fix: Join *employee_salary_structures* and use *AND ess.gross_salary <= 21000* instead of *p.gross_earnings <= 21000*.

3. High Priority Issues (24)

High priority issues include incorrect calculations affecting payroll accuracy, performance degradations, missing data on forms, and security gaps that require immediate attention but do not pose immediate data loss risks.

#	Sev	Category	File	Description
H1	HIGH	Data Integrity	api/payroll-save-row.php:148	attendance_summary upsert missing unit_id (dup of C11)
H2	HIGH	Calculation	entry/quick-salary.php:44	Gross salary missing leave_encashment + bonus_encashment
H3	HIGH	Data Integrity	entry/quick-salary.php:180	MAX() GROUP BY returns Frankenstein salary data
H4	HIGH	Compliance	class.payroll.php:1406	ESI return pro-rated gross (dup of C18)
H5	HIGH	Logic	payroll/bonus.php:37	Wrong status: active vs approved (dup of C17)
H6	HIGH	Operations	process.php:17-44	DDL ALTER TABLE on every page load (8+ files)
H7	HIGH	Data Integrity	api/payroll-save-row.php:229	employee_advances upsert missing unit_id
H8	HIGH	Security	api/crop-save.php:7-58	No CSRF, no file size limit, no image validation, IDOR
H9	HIGH	Security	api/expense-api.php:72-478	No auth, no IDOR, exposes PII
H10	HIGH	Security	api/whatsapp-salary.php:9-10	No role check, GET-based CSRF-able trigger
H11	HIGH	Security	api/manager-units.php:30-206	No auth, returns PII (Aadhaar, bank URLs)
H12	HIGH	Data	employee/add.php:265-268	Missing LWF/Gratuity/OT checkboxes in form
H13	HIGH	Data	class.employee.php:367-380	emergency_contact_number not in directFields
H14	HIGH	Performance	class.employee.php:65-69	checkSalaryTableExists() per query call
H15	HIGH	Data	add.php vs list.php	Semi-skilled vs Semi-Skilled casing mismatch
H16	HIGH	Security	report/custom.php:109-113	SQL injection via column name selection
H17	HIGH	Compliance	report/pf-reports.php:113-115	PF challan on total wages not EPF wages
H18	HIGH	Calculation	class.payroll.php:826-836	Mixed positional/named params holdSalary()
H19	HIGH	Calculation	class.payroll.php:276-277	No mid-month salary revision handling
H20	HIGH	Validation	class.payroll.php:595	No negative net pay protection
H21	HIGH	Performance	muster-roll.php:10-14	DDL ALTER TABLE on every page load
H22	HIGH	Logic	class.payroll.php:346-354	Undefined salary employees not skipped
H23	HIGH	Data	quick-salary.php:97-99	Forces all statutory flags ON for new structures

#	Sev	Category	File	Description
H2 4	HIGH	Compliance	class.payroll.php:1395	ESI return uses employee_code as IP number

Key highlights: Quick Salary Entry calculates gross incorrectly by omitting Leave Encashment and Bonus Encashment (H2), and uses a dangerous MAX() GROUP BY pattern returning salary combinations that never existed (H3). DDL operations are embedded in 8+ page-level files, executing on every request (H6, H21). Employee add form is missing LWF, Gratuity, and OT applicable checkboxes (H12). PF challan calculations use total wages instead of EPF wages for admin/EDLI charges (H17).

4. Medium Priority Issues (22)

#	Sev	Category	File	Description
M1	MEDIUM	Schema	Multiple tables	latin1 charset on 8 tables - cannot store Hindi/special chars
M2	MEDIUM	Schema	employees table	Missing pan_number column (Indian tax identity)
M3	MEDIUM	Schema	employees table	designation is varchar(36) free text, not FK to designations
M4	MEDIUM	Schema	salary_structures	updated_at is varchar(100) instead of timestamp
M5	MEDIUM	Schema	14 ESS tables	employee_id is varchar(50) instead of int
M6	MEDIUM	Schema	epfo_members	dob and doj are varchar(20) instead of DATE type
M7	MEDIUM	Schema	Duplicate tables	8 pairs of duplicate tables need consolidation
M8	MEDIUM	Performance	class.payroll.php:1262	PT slabs hardcoded for only 5 states
M9	MEDIUM	Calculation	class.payroll.php:472	OT uses arbitrary 50% split for basic
M10	MEDIUM	Data Integrity	payroll-save-row.php:219	Closes salary structures on update path
M11	MEDIUM	Reliability	attendance/upload.php:92-218	No transaction for bulk Excel import
M12	MEDIUM	Security	print_payslip.php:25	No session auth check
M13	MEDIUM	Security	class.payroll.php:157-198	No mandatory client_id isolation
M14	MEDIUM	API	api/payroll-update.php:39	No CSRF on POST endpoint
M15	MEDIUM	API	api/bulk-edit.php:37	No CSRF on JSON POST
M16	MEDIUM	API	api/payroll-save-row.php:566	Exception message leaked in JSON
M17	MEDIUM	Navigation	index.php:177-192	employee-search missing from API module map
M18	MEDIUM	Logic	employee/view.php:43-78	Status workflow incomplete
M19	MEDIUM	Data	employee/delete.php:27-29	Bypasses class delete() method
M20	MEDIUM	Reports	report/attendance.php:68-76	Hardcoded 30-day month for absenteeism
M21	MEDIUM	Security	download_salary_template.php	No auth, dumps employee names as CSV
M22	MEDIUM	Security	config/config.php:106-109	unserialize() on constants

5. Low Priority Issues (12)

#	Sev	Category	File	Description
L1	LOW	Schema	employees	Duplicate indexes idx_employees_status and idx_employee_status

#	Sev	Category	File	Description
L2	LOW	Schema	employee_advances	Redundant index over UNIQUE key
L3	LOW	Schema	payroll	Redundant idx_payroll_period_emp
L4	LOW	Schema	payroll_periods	Redundant idx_period_month_year
L5	LOW	Schema	attendance_summary	Overlapping unique keys
L6	LOW	Schema	Multiple tables	Missing updated_at on 20+ tables
L7	LOW	Schema	employees	full_name is nullable
L8	LOW	Schema	employees	approved_by is varchar(36) not int
L9	LOW	API	api/employees.php:125	DELETE via GET, no CSRF
L10	LOW	API	api/image-tool.php:218	Debug path in JSON response
L11	LOW	Code Quality	class.employee.php	Duplicated salary data building
L12	LOW	Security	employee/view.php:39-78	No CSRF on approve/reject actions

6. Recommended Fixes and Execution Plan

6.1 Immediate Actions (Before Next Deployment)

These issues must be resolved before any further deployment to prevent data loss, security breaches, or compliance violations. Each represents the highest-risk finding affecting core system functionality.

#	Priority	Action	Effort	Impact
1	CRITICAL	Add authentication to image-tool.php	1h	Prevents unauthenticated PII access
2	CRITICAL	Add OTP to employee portal login	4h	Prevents unauthorized portal access
3	CRITICAL	Fix payroll-update.php: use basic_da	2h	Corrects salary calculations
4	CRITICAL	Fix payroll/view.php: basic_da display	30m	Fixes visible data bug
5	CRITICAL	Fix report status: = 1 to "approved"	1h	Restores 4 broken reports
6	CRITICAL	Fix PF reports: pf_number + is_active	1h	Restores PF report generation
7	CRITICAL	Create daily_attendance table	2h	Enables attendance import
8	CRITICAL	Add unit_id to save-row upserts	1h	Fixes multi-unit corruption
9	HIGH	Add CSRF tokens to all POST APIs	2h	Prevents CSRF attacks
10	HIGH	Add LWF/Gratuity/OT checkboxes	30m	Fixes missing form fields
11	HIGH	Fix quick-salary gross calculation	1h	Corrects ESI eligibility check
12	HIGH	Remove DDL from page-load code	3h	Eliminates metadata lock risk

6.2 Short-Term Actions (Next Sprint)

Database: Convert 8 latin1 tables to utf8mb4 (especially employees). Add 30+ missing indexes on FK columns and date/status columns. Drop 8 confirmed duplicate tables. Add UNIQUE constraints on uan_number, aadhaar_number, pan_number, esic_number, account_number.

Payroll: Refactor processPayroll() to batch queries (N+1 fix). Extract deduction calculation into reusable method. Add negative net pay protection. Implement mid-month revision pro-rating. Fix ESI return IP number and eligibility. Fix PF challan admin/EDLI calculation.

Security: Add IDOR protection to expense-api, manager-units, crop-save. Add file content validation to crop-save. Add auth to download_salary_template. Fix custom report SQL injection via column whitelist. Add emergency_contact_number to employee directFields.

6.3 Medium-Term Actions (Next Quarter)

Foreign Keys: Add FK constraints for all 40+ parent-child relationships. Start with payroll to periods, attendance to employees. Use ON DELETE RESTRICT for financial tables.

Consolidation: Merge 3 leave balance tables into one. Consolidate pfdatabase into epfo_members. Consolidate lwf_rates and professional_tax_rates duplicates. Standardize ESS employee_id from varchar to int.

Architecture: Rename payroll.employee_id to employee_code (high-effort, 30+ files). Add minimum wage validation. Replace hardcoded PT slabs with database-driven lookup supporting all 20+ states.

7. Database Recommended Changes

7.1 Tables to Create

#	Table Name	Referenced By	Priority
1	daily_attendance	class.attendance.php	CRITICAL
2	employee_arrears	payroll/arrears.php	HIGH
3	employee_bonus	payroll/bonus.php	HIGH
4	employee_deployments	deployment/add.php	HIGH
5	employee_family	portal/profile.php	MEDIUM
6	pt_challans	compliance/pt.php	HIGH
7	timesheets	timesheet/create.php	MEDIUM
8	timesheet_entries	timesheet/create.php	MEDIUM
9	manpower_requisitions	requisition/add.php	MEDIUM
10	job_applicants	recruitment/add.php	MEDIUM
11	esi_returns	compliance/esi-return.php	MEDIUM
12	pf_ecr_files	compliance/ecr.php	MEDIUM
13	saved_reports	report/custom.php	LOW
14	fine_register	gumastadhara-fine-register.php	MEDIUM
15	accident_register	Report module	LOW

7.2 Tables to Drop

Table to Drop	Replacement	Reason
employees1, employees2	employees	Identical schema, no PHP refs, GDPR risk
emp_city_allocations	employee_city_allocations	Same purpose, wrong employee_id type
pfdatabase	epfo_members	Same purpose, pfdatabase uses latin1
lwf_state_rates	lwf_rates	Same purpose, rates uses proper FK
professional_tax_slabs	professional_tax_rates	Same purpose, rates uses proper FK
ess_leave_balances	employee_leave_balance	Consolidate to single table
leave_balances	employee_leave_balance	Consolidate to single table

7.3 Critical Indexes to Add

Table	Index Columns	Query Pattern
attendance_summary	(unit_id, month, year)	Monthly attendance by unit
payroll_records	(employee_id)	Employee payroll history
employee_documents	(employee_id, document_type)	Document list by type
leave_applications	(employee_id, status)	Active leave filter
holidays	(state_id, holiday_date)	Holiday calendar by state
minimum_wages	(state_id, industry_id, effective_from)	Wage lookup
salary_revisions	(employee_id, effective_from)	Revision history
notifications	(user_id, is_read)	Notification list

Table	Index Columns	Query Pattern
user_sessions	(session_token), (expires_at)	Session validation
payroll_unit_status	(client_id, status)	Unit status filter

8. Positive Findings

Despite the issues identified, the system demonstrates several strong security and architectural practices that provide a solid foundation. These controls should be maintained and extended to cover the gaps identified in this audit.

Control	File	Details
Parameterized Queries	class.database.php	PDO EMULATE_PREPARES=false, all methods use ?/:param placeholders
Password Hashing	class.auth.php	PASSWORD_BCRYPT cost=12, password_verify() for checking
Brute Force Protection	class.auth.php	5=15min, 10=1hr, 20=24hr lockout, DB-backed
Session Security	config/config.php	HttpOnly, SameSite=Strict, Secure, custom path, 30min idle
CSRF Protection	auth/login.php	validateCSRFTOKEN with hash_equals timing-safe compare
Security Headers	index.php	X-Frame-Options, X-Content-Type-Options, HSTS, Referrer-Policy
Path Traversal	index.php	sanitizePageParam + realpath + module whitelist
RBAC System	class.auth.php	Per-role, per-menu, per-submenu, per-action granularity
Audit Logging	audit_log.php	Centralized, non-blocking, used consistently
XSS Prevention	config/config.php	Global sanitize() = htmlspecialchars(ENT_QUOTES, UTF-8)

9. Cross-Module Data Flow Validation

This section verifies that data flows correctly between interconnected modules. Each row represents a data dependency between two modules, with the current status and any issues identified.

Source	Target	Data Flow	Status	Issues
Attendance Entry	Payroll Processing	attendance_summary	BROKEN	Missing daily_attendance table; upsert missing unit_id
Salary Entry	Payroll Processing	salary_structures	PARTIAL	MAX() GROUP BY Frankenstein data; no versioning
Employee Module	Attendance Module	employees.id + status	OK	Status values inconsistent
Employee Module	Payroll Processing	salary_structures	OK	No mid-month revision handling
Payroll Processing	Salary Register	payroll table	BROKEN	basic/da columns do not exist
Payroll Processing	Bank Advice	payroll table	OK	Net pay can be negative
Payroll Processing	Payslips	payroll table	BROKEN	basic/da always show 0
Payroll Processing	PF Reports	payroll + employees	BROKEN	pf_number does not exist
Payroll Processing	ESI Reports	payroll + employees	BROKEN	Wrong eligibility check; wrong IP number
Employee Module	Loan Module	employee_loans	OK	Loan EMI correctly deducted
Advance Entry	Payroll Processing	employee_advances	PARTIAL	Missing unit_id scope in API